

E-Commerce Website Testing and Compliance Audit Report

Target System: <https://bhrikutimandap.com>

Standards Referenced:

- *ISO/IEC 27001 & 27002 (Information Security Management)*
 - *OWASP Web Security Testing Guide & OWASP Top 10*
 - *NIST SP 800-115 & NIST SP 800-53*
 - *WCAG 2.0 / 2.1 / 2.2*
-

1. Executive Summary

This audit evaluates the ecommerce platform for functional reliability, security posture, and accessibility compliance. The assessment methodology aligns with ISO 27001 risk-based controls, OWASP security testing methodology, NIST technical security testing guidance, and WCAG accessibility success criteria.

2. Audit Scope

2.1 In-Scope

- Public website frontend
- User authentication and checkout
- Application APIs
- Accessibility and usability features

2.2 Out-of-Scope

- Hosting infrastructure
 - Third-party payment provider internal systems
 - Internal corporate network
-

3. Audit Methodology

3.1 Testing Frameworks

Framework	Purpose
ISO 27001	Information security governance
OWASP	Web vulnerability testing
NIST 800-115	Technical security testing methodology
WCAG 2.x	Accessibility compliance

3.2 Testing Phases

1. Planning and scoping
 2. Information gathering
 3. Vulnerability discovery
 4. Validation and exploitation
 5. Reporting and remediation
-

4. Detailed Test Cases

4.1 Functional Test Cases

TC ID	Test Case	Steps	Expected Result
FT-01	Homepage Load	Open site URL	Page loads without errors
FT-02	Product Search	Search valid product	Relevant results displayed
FT-03	Cart Add Item	Add product to cart	Cart updates correctly
FT-04	Cart Quantity Update	Change quantity	Price updates correctly
FT-05	Checkout Validation	Submit empty fields	Error messages displayed

Confidential

TC ID	Test Case	Steps	Expected Result
FT-06	Order Placement	Complete checkout	Order confirmation displayed

4.2 Security Test Cases (OWASP / NIST)

Authentication & Session

TC ID	Test Case	Steps	Expected Result
ST-01	Weak Password Test	Register weak password	System rejects password
ST-02	Brute Force Test	Attempt multiple logins	Account locked or rate limited
ST-03	Session Hijack	Reuse session cookie	Session invalid after logout

Injection & Input Validation

TC ID	Test Case	Steps	Expected Result
ST-04	SQL Injection	Inject ' OR 1=1--	No data leakage
ST-05	XSS Test	Inject <script>alert(1)</script>	Script not executed

Access Control

TC ID	Test Case	Steps	Expected Result
ST-06	IDOR	Modify order ID	Access denied
ST-07	Admin Access	Access admin URL	Access denied

Business Logic

TC ID	Test Case	Steps	Expected Result
ST-08	Price Tampering	Modify price in request	Server rejects
ST-09	Checkout Bypass	Skip checkout steps	Order not processed

4.3 Accessibility Test Cases (WCAG)

TC ID	Test Case	Steps	Expected Result
AT-01	Alt Text	Inspect images	All have alt attributes
AT-02	Keyboard Navigation	Use Tab key	All features accessible
AT-03	Screen Reader	Test with NVDA	Content readable
AT-04	Contrast Ratio	Check contrast	Meets WCAG AA
AT-05	Form Labels	Inspect form fields	Labels associated

5. Risk Classification

Severity Description

Critical Immediate exploitation risk

High Sensitive data exposure possible

Medium Security weakness with mitigation

Low Informational or best practice

6. Compliance Mapping Tables

6.1 OWASP Top 10 Mapping

OWASP Category	Test Cases
A01: Broken Access Control	ST-06, ST-07
A02: Cryptographic Failures	ST-01, ST-03
A03: Injection	ST-04, ST-05
A05: Security Misconfiguration	TLS/Headers checks

Confidential

OWASP Category	Test Cases
A07: Identification & Authentication Failures	ST-01, ST-02
A10: SSRF (if APIs exist)	API testing

6.2 NIST SP 800-53 Mapping

NIST Control Description		Test Area
AC-2	Account Management	Authentication tests
AC-6	Least Privilege	Access control tests
IA-2	User Identification	Login testing
SC-12	Cryptographic Key Establishment	TLS testing
SI-10	Input Validation	Injection testing
AU-2	Audit Logging	Log verification

6.3 WCAG Mapping Table

WCAG Principle	Success Criteria	Test Cases
1.1 Perceivable	Text Alternatives	AT-01
1.4 Perceivable	Contrast	AT-04
2.1 Operable	Keyboard	AT-02
3.3 Understandable	Error Identification	Form testing
4.1 Robust	Compatible	AT-03

7. Deliverables

1. Functional Test Report
2. Security Vulnerability Assessment

3. Accessibility Conformance Report (ACR / VPAT style)
 4. Risk Register
 5. Remediation Recommendations
-

8. Audit Conclusion Template

The ecommerce system was assessed against ISO 27001-aligned security controls, OWASP web security testing guidelines, NIST technical testing methodology, and WCAG accessibility requirements. Identified risks were classified and remediation guidance provided. Compliance readiness is rated as [Compliant / Partially Compliant / Non-Compliant].

Professional Audit Checklist (Final)

Functional

- ☐ Navigation verified
- ☐ Search and filtering tested
- ☐ Cart and checkout validated
- ☐ Account features tested

Security

- ☐ HTTPS and TLS validated
- ☐ Authentication tested
- ☐ Injection testing performed
- ☐ Access control verified
- ☐ Business logic tested
- ☐ Vulnerability scan completed

Accessibility

- ☐ Alt text verified

Confidential

- ☐ Keyboard navigation tested
- ☐ Screen reader compatibility tested
- ☐ Contrast and text resizing verified

Compliance

- ☐ OWASP mapping completed
- ☐ NIST control mapping completed
- ☐ WCAG success criteria mapped
- ☐ Risk report completed
- ☐ Retesting performed

Manual Testing & Recommendations Checklist

✓	Issue / Recommendation	Status
☐	Cannot edit the Featured Place section. A slider bar with automatic transitions should be implemented.	☐ Pending
☐	Clicking on product images shows 400 Bad Request. It should open the product page with description.	☐ Pending
☐	Navbar should include product categories (Men, Women, Kids, Accessories) for easy browsing.	☐ Pending
☐	Featured section currently covers the whole page; it should be positioned in the middle.	☐ Pending
☐	OTP verification should be sent to user's phone number during registration.	☐ Pending
☐	Payment currency is displayed in Indian Rupee (INR); it should be changed to Nepali Rupee (NPR).	☐ Pending
☐	First homepage image is not properly aligned/equal; layout needs correction.	☐ Pending
☐	Agent (seller) can upload only one product image; multiple image upload should be enabled.	☐ Pending
☐	Agent cannot directly access agent portal; add option to switch between Agent Dashboard and Consumer/Home Dashboard.	☐ Pending
☐	Add "View Password" option during login for user convenience.	☐ Pending
☐	After password reset via Gmail link, newly created accounts show "Invalid Credentials" on login; needs fixing.	☐ Pending

☐ our webpage should have its own unique theme colour which should be related to the logo. ☐ Pending

☐ There should be a customer care helpline service [ai chat bot] which will give the answers/queries of the customer. ☐ Pending

☐ After clicking on the product, there should also be a buy now option as well as a chat option with the seller, so that consumers can directly talk to seller and get extra details about the products, and also by clicking at the name of the store in the product we could visit the seller home page where we can watch there other products too. ☐ Pending

☐ While giving a review, the reviewing stars should be in yellow colour, and the reviews should be shown before clicking into the products, like reviews should be placed in the bottom of the thumbnail or in its name. ☐ Pending

☐ _____

☐ _____

☐ _____

☐ _____

☐ _____

☐ _____

☐ _____

☐ _____

☐ _____

☐ _____

☐ _____

☐ _____

Business registration process:

First step is to reserve the company name from OCR (ONLINE COMPANY REGISTRATION) website , as I had personally looked over the OCR website, I haven't found any company registered with the name Bhrikuti Mandap or Bhrikutimandap.

After registration, it will take few days, like 2 or 3 days.

after reserving the name, we should prepare these documents to register the company

- 1. Director/Owner citizenship copy and Passport-size photo**
- 2. MOA (Memorandum of association)**
- 3. AOA (Article of Association)**
- 4. Office address proof (rent agreement or owned property)**

Once the name is approved, Fill the company registration form from OCR website and upload all the documents. Next pay the registration fee and the n OCR will review and issue Company Registration Certificate.

Then the next step is to go to Inland Revenue Department (IRD) website to apply for company PAN number (PAN) is required for tax purposes and opening bank account.

After that, we can set up payment gateway for e-commerce (esewa, khalti, connectIPS, etc.)

Confidential